

Backend Database Schema & Data Ownership Specification

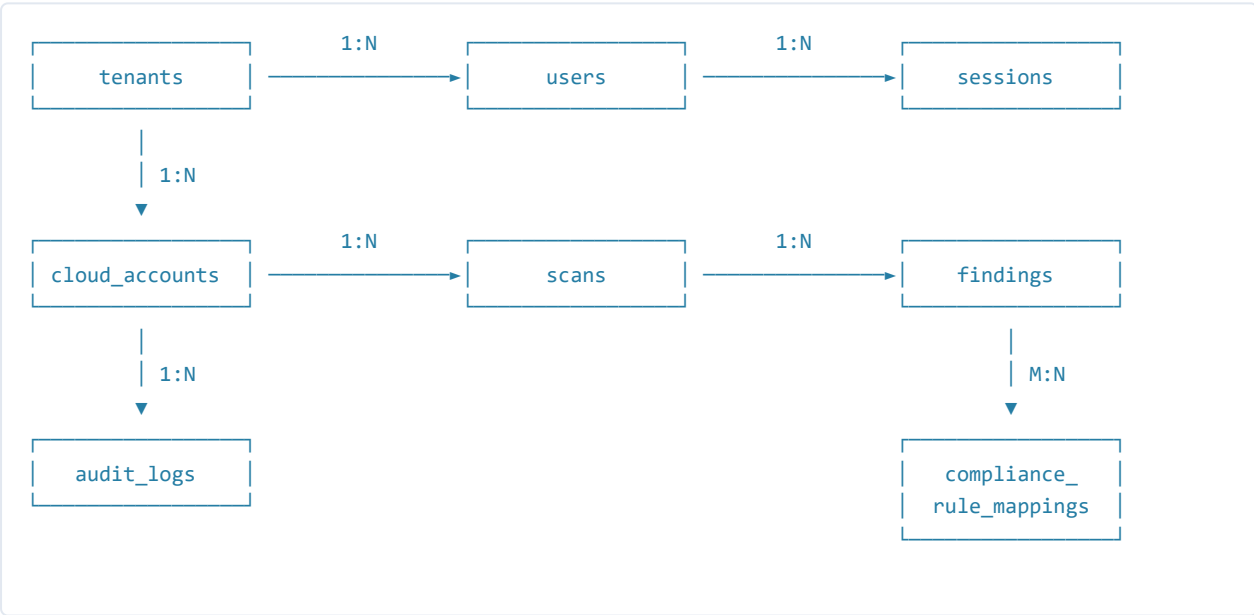
App Name: CloudGuard GRC (AntiGravity Platform Architecture)[cite: 1]

Database Engine: AWS RDS PostgreSQL v15+ (Relational Core) + AWS S3 (Raw Audits)[cite: 1]

Document Version: 1.0.0 (Data Models, Relationships, Indexes & Multi-Tenancy)

1. Entity Relationship Overview & Foreign Key Hierarchy

CloudGuard GRC utilizes a strict multi-tenant database design where all core application tables cascade down from a master `tenants` organization record[cite: 1]. Data isolation is guaranteed at the API and database levels via Tenant IDs and PostgreSQL Row-Level Security (RLS) policies[cite: 1].



2. Table Definitions & Column Specifications

Table 1: `tenants` (Organizations / Enterprise Accounts)

Stores customer tenant metadata, plan tiers, and organization settings[cite: 1].

Column Name	Data Type	Constraints	Description
<code>id</code>	UUID	PRIMARY KEY , DEFAULT <code>gen_random_uuid()</code>	Unique global tenant identification string.
<code>company_name</code>	VARCHAR(255)	NOT NULL	Name of the customer enterprise or startup[cite: 1].

Column Name	Data Type	Constraints	Description
subscription_plan	VARCHAR(50)	NOT NULL, DEFAULT 'FREE'	Plan tier ('FREE', 'PRO', 'ENTERPRISE')[cite: 1].
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Tenant registration timestamp.
updated_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Last organization update timestamp.

Table 2: users (User Accounts & IAM Roles)

Stores registered user identities, password hashes, and assigned application roles[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Unique user identifier.
tenant_id	UUID	FOREIGN KEY -> tenants(id) ON DELETE CASCADE	Associated parent organization ID.
email	VARCHAR(255)	NOT NULL, UNIQUE	User email address (used for login) [cite: 1].
password_hash	VARCHAR(255)	NOT NULL	Argon2id or Bcrypt secure password digest.
full_name	VARCHAR(100)	NOT NULL	User display name[cite: 1].
role	VARCHAR(50)	NOT NULL, DEFAULT 'VIEWER'	Role ('SUPER_ADMIN', 'ACCOUNT_ADMIN', 'ANALYST', 'AUDITOR', 'VIEWER')[cite: 1].
is_active	BOOLEAN	NOT NULL, DEFAULT TRUE	Account status toggle.
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Record creation timestamp.

Table 3: sessions (Auth & Session Handling)

Tracks active JWT refresh token hashes and device session states[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Session identifier token.
user_id	UUID	FOREIGN KEY -> users(id) ON DELETE CASCADE	Associated user record.
refresh_token_hash	VARCHAR(255)	NOT NULL, UNIQUE	Hashed refresh token for OAuth2 token rotation.

Column Name	Data Type	Constraints	Description
ip_address	VARCHAR(45)	NULLABLE	IPv4/IPv6 address of the login request.
user_agent	TEXT	NULLABLE	Browser/CLI client user agent string.
expires_at	TIMESTAMPTZ	NOT NULL	Expiration timestamp for the refresh session.
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Session issuance timestamp.

Table 4: cloud_accounts (Connected Cloud Accounts)

Stores onboarded AWS, Azure, and GCP environment connection credentials[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Internal account UUID.
tenant_id	UUID	FOREIGN KEY -> tenants(id) ON DELETE CASCADE	Parent tenant ownership link.
provider	VARCHAR(20)	NOT NULL	Cloud provider ('AWS', 'AZURE', 'GCP')[cite: 1].
account_number	VARCHAR(100)	NOT NULL	AWS 12-digit Account ID or Azure Subscription ID[cite: 1].
account_alias	VARCHAR(100)	NOT NULL	User-defined display name (e.g., 'Production-AWS')[cite: 1].
role_arn	VARCHAR(255)	NOT NULL	AWS Read-Only IAM Role ARN ('arn:aws:iam::...')[cite: 1].
external_id	VARCHAR(255)	NOT NULL	Unique string preventing Confused Deputy attacks[cite: 1].
connection_status	VARCHAR(50)	NOT NULL, DEFAULT 'PENDING'	Status ('ACTIVE', 'PENDING', 'ERROR', 'DISCONNECTED') [cite: 1].
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Onboarding timestamp[cite: 1].

Table 5: scans (Scan Execution Jobs)

Records scan job history, execution states, and aggregated risk summaries[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Scan execution ID.

Column Name	Data Type	Constraints	Description
cloud_account_id	UUID	FOREIGN KEY -> cloud_accounts(id) ON DELETE CASCADE	Target cloud account being audited[cite: 1].
trigger_type	VARCHAR(50)	NOT NULL	Trigger origin ('MANUAL', 'SCHEDULED', 'CI_CD_HOOK')[cite: 1].
status	VARCHAR(50)	NOT NULL, DEFAULT 'QUEUED'	Job state ('QUEUED', 'IN_PROGRESS', 'COMPLETED', 'FAILED')[cite: 1].
threat_score	INTEGER	NULLABLE	Calculated weighted risk score (0 - 100)[cite: 1].
total_findings	INTEGER	DEFAULT 0	Total count of misconfigurations detected[cite: 1].
raw_log_s3_key	VARCHAR(255)	NULLABLE	S3 object key containing raw JSON scan payload[cite: 1].
started_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Scan execution start time.
completed_at	TIMESTAMPTZ	NULLABLE	Scan job completion timestamp[cite: 1].

Table 6: findings (Security Misconfigurations & Exposed Secrets)

Stores detailed policy violations, risk severities, and remediation code snippets[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Finding UUID.
scan_id	UUID	FOREIGN KEY -> scans(id) ON DELETE CASCADE	Origin scan job link[cite: 1].
tenant_id	UUID	FOREIGN KEY -> tenants(id) ON DELETE CASCADE	Tenant isolation boundary key[cite: 1].
rule_id	VARCHAR(100)	NOT NULL	Benchmark rule key (e.g., 'cis-aws-2.1.1-s3-public')[cite: 1].
service_name	VARCHAR(50)	NOT NULL	AWS service ('S3', 'IAM', 'EC2', 'RDS', 'KMS')[cite: 1].
resource_arn	TEXT	NOT NULL	Target AWS resource string[cite: 1].
severity	VARCHAR(20)	NOT NULL	Severity ('CRITICAL', 'HIGH', 'MEDIUM', 'LOW', 'INFO')[cite: 1].

Column Name	Data Type	Constraints	Description
status	VARCHAR(50)	NOT NULL, DEFAULT 'OPEN'	Status ('OPEN', 'RESOLVED', 'SUPPRESSED')[cite: 1].
title	VARCHAR(255)	NOT NULL	Summary of the security vulnerability[cite: 1].
remediation_json	JSONB	NOT NULL	JSON object containing Terraform and CLI fix snippets[cite: 1].
detected_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	First detection timestamp[cite: 1].

Table 7: audit_logs (System & Compliance Action Audit Trail)

Stores chronological application action logs for compliance auditing and forensic tracking[cite: 1].

Column Name	Data Type	Constraints	Description
id	UUID	PRIMARY KEY , DEFAULT gen_random_uuid()	Audit entry UUID.
tenant_id	UUID	FOREIGN KEY -> tenants(id) ON DELETE CASCADE	Associated organization ID[cite: 1].
user_id	UUID	FOREIGN KEY -> users(id) ON DELETE SET NULL	User executing the action (NULL if automated system)[cite: 1].
action_type	VARCHAR(100)	NOT NULL	Action key (e.g., 'ACCOUNT_ADDED', 'FINDING_SUPPRESSED')[cite: 1].
metadata_json	JSONB	NULLABLE	Contextual details (IP address, affected resource, parameters)[cite: 1].
created_at	TIMESTAMPTZ	NOT NULL, DEFAULT CURRENT_TIMESTAMP	Log timestamp (retained for 1+ years) [cite: 1].

3. Indexes & Database Performance Tuning

To ensure fast REST API response times (< 200ms p95) and prevent query lag during large multi-account scans, the following index structures are enforced[cite: 1]:

```
-- Fast filtering of findings by Tenant, Severity, and Status
CREATE INDEX idx_findings_tenant_severity
ON findings (tenant_id, severity, status);

-- Rapid lookup for findings under a specific cloud account scan
CREATE INDEX idx_findings_scan_id
ON findings (scan_id);

-- JSONB GIN Index for fast querying of Terraform remediation snippets inside JSON
CREATE INDEX idx_findings_remediation_gin
ON findings USING GIN (remediation_json);
```

```
-- Fast user lookup during authentication
CREATE INDEX idx_users_email
ON users (email);

-- Query optimization for historical audit log exports
CREATE INDEX idx_audit_logs_tenant_created
ON audit_logs (tenant_id, created_at DESC);
```

4. Application RBAC & Row-Level Security (RLS) Rules

Role Permission Matrix

Application Role	Onboard Accounts	Trigger Scans	View Findings	Remediate / Suppress	Export Audit Reports
Super Admin	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]
Cloud Account Admin	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]
Security Analyst	X[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]	✓[cite: 1]
Auditor (Read-Only)	X[cite: 1]	X[cite: 1]	✓[cite: 1]	X[cite: 1]	✓[cite: 1]
Viewer	X[cite: 1]	X[cite: 1]	✓ (Summary Only) [cite: 1]	X[cite: 1]	X[cite: 1]

Data Ownership & Multi-Tenant Isolation Enforcement

- **Database Row-Level Security (RLS):** PostgreSQL Row-Level Security is enabled on the findings , cloud_accounts , and audit_logs tables[cite: 1].
- **Session Context Injection:** Upon processing an authenticated REST API request, the FastAPI backend injects the decoded JWT's tenant_id into the active database transaction context using SET LOCAL app.current_tenant_id = 'tenant_uuid_here'; .
- **RLS Isolation Policy Example:**

```
-- Enable RLS on Findings Table
ALTER TABLE findings ENABLE ROW LEVEL SECURITY;

-- Enforce strict isolation: Users can only query findings matching their tenant context
CREATE POLICY tenant_isolation_policy ON findings
FOR ALL
USING (tenant_id = current_setting('app.current_tenant_id')::UUID);
```